

SOC FUNDAMENTALS

What Is a SOC?

A **Security Operations Center (SOC)** is a centralized function within an organization that continuously monitors, detects, prevents, investigates, and responds to cybersecurity threats. It's the **nerve center of cybersecurity operations**, combining **people, processes, and technology** to secure an organization's digital assets.

Goal: Ensure the confidentiality, integrity, and availability (CIA triad) of systems and data.

Types of SOC Models

Organizations choose a SOC model based on their **size, budget, risk tolerance**, and **regulatory requirements**:

1. In-house SOC

- Entirely owned, staffed, and operated by the organization.
- Offers **greater control and customization**, but requires **large investment and skilled personnel**.
- **Best for:** Large enterprises with sensitive data or compliance mandates (e.g., banks, healthcare).

2. Virtual SOC

- A **remote or distributed team** without a centralized physical location.
- Flexible and cost-effective but may face challenges in **real-time collaboration**.
- **Best for:** SMEs, startups, or fully remote organizations.

3. Co-Managed SOC

- Combines **internal staff** with external **Managed Security Service Providers (MSSPs)**.
- Helps balance in-house knowledge with outsourced expertise.
- **Best for:** Organizations looking to **scale up security** without full ownership.

4. Command SOC

- Acts as a **central hub** controlling multiple regional or specialized SOC's.
- Often used by **large-scale or multinational enterprises**, government, and military.
- **Best for:** Organizations with **multiple business units** or **global reach**.

Core Pillars of a SOC: People, Process, Technology

People

The human element is the **first line of defense**.

- Must have up-to-date knowledge of **current attack vectors** and **threat intelligence**.
- Roles must be **well-defined** to avoid alert fatigue and response bottlenecks.

Process

- Includes **standard operating procedures (SOPs)**, playbooks, and escalation paths.
- Must align with **industry frameworks** like:
 - **NIST Cybersecurity Framework**
 - **ISO/IEC 27001**
 - **HIPAA, PCI-DSS, etc.**
- Helps maintain **consistency, compliance, and documentation**.

Technology

- Core tools include:
 - **SIEM (e.g., Splunk, QRadar)**: Aggregates and correlates log data.
 - **EDR (e.g., CrowdStrike, SentinelOne)**: Monitors and responds to endpoint threats.
 - **SOAR (e.g., Cortex XSOAR, IBM Resilient)**: Automates incident response.
 - **Firewall, IDS/IPS, DLP, and Threat Intel Platforms**.

 **Tip:** The “best” tech is the one that suits your **team's capability, organization's threat model, and budget**—not necessarily the one with the most features.

SOC Roles Explained

Here's how the various roles typically break down in a SOC hierarchy:

◆ SOC Analyst

- **Tier 1:** Initial alert triage and categorization (e.g., phishing, failed logins).
- **Tier 2:** Deeper investigation, validation, and escalation of threats.
- **Tier 3:** Threat hunting, malware analysis, advanced correlation.

Analysts are the **backbone of the SOC**, handling alerts from tools like SIEM, EDR, and firewalls.

◆ Incident Responder

- Performs **containment, eradication, and recovery** during active threats.
- Documents and reports incidents per regulatory and internal guidelines.

Focus: **React quickly and limit damage** in a live cyber incident.

◆ Threat Hunter

- Proactively searches for undetected threats using hypotheses and telemetry data.
- Relies on **behavioral analytics, threat intel, and anomaly detection**.

Goal: Catch **Advanced Persistent Threats (APTs)** that slip past automated defenses.

◆ **Security Engineer**

- Designs, maintains, and optimizes the SOC’s toolset (e.g., SIEM rules, playbooks).
- Integrates platforms like **SOAR**, vulnerability scanners, and asset management.

Essential for **keeping tools updated, tuned, and integrated** across the security stack.

◆ **SOC Manager**

- Oversees operations, people, and resources.
- Manages shift schedules, KPIs, hiring, and vendor relations.

Focus: Maintain **strategic alignment**, optimize **team performance**, and ensure **SLAs are met**.

← **Summary**

Role	Main Responsibility	Skill Level
Tier 1 Analyst	Alert triage & ticketing	Entry-level
Tier 2 Analyst	Investigation & correlation	Intermediate
Tier 3 Analyst	Threat analysis & escalation	Advanced
Incident Responder	Incident handling & recovery	Advanced
Threat Hunter	Proactive threat detection	Advanced
Security Engineer	Tool management & SOC infrastructure	Technical
SOC Manager	Team coordination & strategic operations	Managerial

What is a SOC Analyst?

A **SOC Analyst** (Security Operations Center Analyst) is a cybersecurity professional who acts as the **first line of defense** against cyber threats. They are responsible for **monitoring security systems**, **analyzing alerts**, and **investigating potential security incidents**.

SOC Analysts usually work in **shifts** to provide 24/7 coverage, ensuring continuous protection of the organization’s digital assets.

Think of them as digital security guards who patrol systems and respond when something suspicious happens.

👥 **Where Does a SOC Analyst Fit Into the SOC Team?**

In a typical SOC hierarchy, SOC Analysts are organized into different tiers:

- **Tier 1 (L1):** Entry-level analysts who **triage alerts**, identify false positives, and escalate real threats.

- **Tier 2 (L2):** Analysts who **investigate further**, correlate data from multiple sources, and provide detailed reports.
- **Tier 3 (L3):** Senior analysts or threat hunters who handle **complex threats**, perform root cause analysis, and suggest improvements.

The SOC Analyst role is **critical** because it's the first point of contact when a threat is detected. The speed and accuracy of their analysis can greatly influence how effectively a threat is contained.

Advantages of Being a SOC Analyst

One of the main benefits of being a SOC Analyst is the **variety of threats and techniques** you'll encounter. Unlike jobs where tasks are repetitive, a SOC Analyst faces different scenarios regularly:

- You might analyze a **phishing email** one day, and a **ransomware attack** the next.
- Even if the tools (like Windows, EDR, and SIEM) remain constant, **the nature of threats keeps changing**, making the job dynamic and engaging.

Additionally, since attackers are always coming up with new methods, SOC analysts are constantly learning, researching, and improving their skills—helping them grow faster in their careers.

A Day in the Life of a SOC Analyst

Here's what a typical day looks like for a SOC Analyst:

1. **Start the shift** by checking for any critical alerts or handovers from the previous team.
2. Log in to the **SIEM (Security Information and Event Management)** system to review alerts generated by firewalls, antivirus, servers, and other security tools.
3. Identify which alerts are **false positives** (not real threats) and which ones require further investigation.
4. Use tools such as:
 - **EDR (Endpoint Detection and Response)** to examine endpoint behavior.
 - **SOAR (Security Orchestration, Automation, and Response)** to automate repetitive tasks.
 - **Log management systems** to cross-reference activities across devices.
5. Investigate IP addresses, domains, or file hashes involved in suspicious activity.
6. If a genuine threat is found, escalate the case to senior analysts or incident responders.

This role requires constant alertness, attention to detail, and decision-making under pressure.

Essential Skills for a SOC Analyst

To succeed as a SOC Analyst, you need more than just tool knowledge. You must also understand how systems and networks work to detect abnormalities.

1. Operating System Knowledge (Windows/Linux)

- Many alerts involve system processes or registry changes.

- For example: If a new service is created in Windows, is it legitimate or part of a malware infection?
- You need to know what processes/services normally run and what looks suspicious.

Example: svchost.exe is a legitimate process in Windows—but if it's running from a suspicious path like C:\Temp\svchost.exe, it could be malware impersonating a system process.

2. Networking Basics

- You'll often analyze **malicious IP addresses, ports, and protocols**.
- You must determine whether:
 - An internal device is communicating with a **known malicious server**.
 - A **sensitive file** was exfiltrated from the network.
- Understanding concepts like **DNS, TCP/IP, VPNs, firewalls, and routing** is crucial.

Example: If a host is reaching out to an unusual IP on port 4444 (often used by malware), is it part of a reverse shell connection?

3. Malware Analysis (Basic)

- You don't need to be an expert reverse engineer, but you should:
 - Identify **command and control (C2)** communication.
 - Check file hashes against threat intelligence databases (e.g., VirusTotal).
 - Understand how malware behaves on infected systems.

Example: A malicious .exe file triggers an alert. You discover it opens a backdoor and connects to hxxp://badserver[.]com. You then check if any systems on your network are communicating with that domain.

Key Takeaways

- SOC Analysts are **critical to identifying and escalating cyber threats** before they become major incidents.
- The role involves continuous learning, making it ideal for anyone passionate about cybersecurity.
- Success requires a solid foundation in **operating systems, networking, and malware behavior**—not just tool usage.
- As you grow in this role, you can transition into more advanced positions like **Threat Hunter, Incident Responder, or Security Engineer**.

What is SIEM?

SIEM stands for **Security Information and Event Management**. It is a **centralized platform** that collects, normalizes, analyzes, and stores security event data from various sources across an organization's IT environment.

Key Functions of SIEM:

- **Log Collection:** Collects logs from devices like firewalls, servers, endpoints, and applications.
- **Event Correlation:** Identifies patterns or relationships between events.
- **Alerting:** Generates alerts when suspicious or predefined behavior occurs.
- **Dashboarding & Reporting:** Visualizes security data for easier interpretation and compliance.
- **Forensics & Investigation:** Supports in-depth analysis of incidents.

Purpose: The ultimate goal of SIEM is to **detect security threats in real time** and help teams **respond quickly**.

Why Is SIEM Important for SOC Analysts?

SOC Analysts **rely heavily on SIEM tools** to detect and investigate potential threats. Although a SIEM can collect vast amounts of data, its true value comes from the ability to **create filters and rules** that highlight only **suspicious or abnormal behavior**.

Example of a SIEM Alert:

Alert Scenario: A user attempts to log in with the wrong password 20 times within 10 seconds.

This is a **brute-force login attempt**. No normal user behavior would involve this many attempts in such a short span. So, a **correlation rule** is written in SIEM to detect this activity and generate an **alert** when it happens.

Role of the SOC Analyst in This Context:

- The SOC analyst receives the alert.
- Analyzes its **validity** using additional tools.
- Determines if it's a **real threat** (true positive) or a **false alarm** (false positive).
- Takes appropriate action or **escalates** if needed.

Common SIEM Tools

Some popular SIEM platforms used in the industry include:

- **Splunk**
- **IBM QRadar**
- **ArcSight ESM**
- **FortiSIEM**
- **Azure Sentinel**
- **LogRhythm**

These platforms integrate with **EDR, firewalls, Active Directory**, and **cloud platforms** to collect and analyze security logs in one place.

Relationship Between SOC Analyst and SIEM

While SIEM systems offer many advanced features (like threat intelligence, anomaly detection, and compliance reports), **SOC Analysts primarily interact with alerts** generated by the system.

✖ The Process:

1. **Raw logs** are ingested into the SIEM.
2. **Rules and filters** are applied to detect suspicious patterns.
3. **Alerts** are triggered for potentially malicious activity.
4. **SOC Analyst reviews the alert** and gathers evidence:
 - IP addresses
 - Usernames
 - Hostnames
 - File hashes
 - URLs or domains involved
5. The analyst uses supporting tools such as:
 - **EDR** (e.g., CrowdStrike, SentinelOne)
 - **Log Management**
 - **Threat Intelligence Feeds**
6. The analyst determines if the activity is:
 - A **real attack**: escalate or respond.
 - A **false alert**: document and possibly recommend rule improvement.

💡 Practical Scenario – Alert Ownership

On platforms like **LetsDefend**, analysts simulate a real SOC workflow. For example:

- All incoming alerts are visible in the **Main Channel** (shared queue).
- When you begin working on an alert, you click **“Take Ownership”** to move it to the **Investigation Channel**.
- This makes your teammates aware that you're working on it, preventing duplication of effort.

This mimics **real-world team collaboration**, where every analyst has visibility into who is working on what, improving alert handling efficiency.

⚠ Quick Tip: Handling False Positives

False positives are common in SIEM. A smart SOC analyst can **identify patterns** in unnecessary alerts and **suggest improvements** to the SIEM team.

🔧 Example:

Let's say a rule flags any URL containing the word **"union"** (to detect SQL injection). But a user searches:

<https://www.google.com/search?q=sql+union+usage>

This is a legitimate search, not an attack. The SOC analyst should:

- **Mark it as a false positive.**
- **Inform the SIEM engineering team** to improve the rule—perhaps by including other SQL injection indicators.

This feedback loop enhances the **precision** of the SIEM over time.

Final Thoughts

- SIEM is a **core tool for any SOC team**—it's where threat detection begins.
- A SOC Analyst's effectiveness largely depends on their ability to **interpret and act on SIEM alerts**.
- As you grow in your role, understanding the **logic behind SIEM rules** and collaborating with rule creators will make you more valuable to your SOC team.

What is Log Management?

Log Management is the process of **collecting, centralizing, analyzing, and storing logs** from different sources across an organization's IT infrastructure. These logs might come from:

- Operating systems (e.g., Windows Event Logs)
- Network devices (e.g., firewalls, routers)
- Security tools (e.g., EDR, antivirus)
- Applications (e.g., web servers, email servers)
- Cloud environments (e.g., Azure, AWS)

Rather than accessing each log source separately, **log management systems provide a centralized interface**, making analysis **faster, more accurate**, and **less error-prone**.

Why Does Log Management Matter for a SOC Analyst?

SOC analysts **frequently investigate incidents** that require correlating information across multiple systems. Without centralized logs, this would be a painful and inefficient process.

Example: If malware is communicating with a suspicious domain like `letsdefend.io`, you need to quickly check if **any devices in the organization** have interacted with that domain.

Without log management:

- You'd need to manually log into different systems (e.g., proxy server, firewall, DNS logs).
- Each system may use different formats or search syntax.
- It's slow, inefficient, and prone to human error.

With centralized log management:

- **One query** can check all logs.
- Results are easier to interpret and act on.
- It speeds up **threat hunting, incident response, and forensics**.

Practical Use of Log Management

Use Case 1: Finding Malware C2 Communications

Imagine you found a suspicious file during an investigation, and sandbox analysis revealed it communicates with letsdefend.io (a **Command & Control server**).

Your task: Check if any other systems in the network communicated with letsdefend.io.

Steps using Log Management:

1. Go to the log management console.
2. Search for letsdefend.io or its IP address.
3. Analyze results from various sources (Proxy, DNS, Firewall).
4. Identify any infected or communicating endpoints.
5. Take response actions if needed (isolate, alert, escalate).

Use Case 2: Investigating Beyond a Single Alert

You receive a **SIEM alert** showing that **LetsDefendHost** is exfiltrating data to a suspicious IP: 122[.]194[.]229[.]59.

You've responded:

- Isolated the system.
- Conducted forensics.
- Blocked the IP.

But as a diligent analyst, you need to ask:

"Is any **other device** talking to the same IP?"

With Log Management, you:

1. Search for 122.194.229.59 across all logs.
2. Identify other potential compromised hosts.
3. Get context: When did it start? How often did it happen? What data was transferred?
4. Build a full picture of the attack scope.

Important Tips for SOC Analysts

What to Look For in Logs:

- **Source/Destination IPs**
- **Domain names / URLs**
- **Timestamps** of events
- **Usernames / Accounts involved**
- **HTTP methods, status codes** (in web logs)
- **Process names, command lines** (in endpoint logs)

What Not to Do:

- Don't assume a single alert tells the whole story.
- Don't ignore context — even benign-looking logs can reveal lateral movement or staging behavior.

Summary of Log Management's Role

Feature	Why It Matters
Centralized log access	Saves time, reduces errors
Fast search and correlation	Speeds up threat detection & response
Historical visibility	Helps in long-term threat investigations
Source diversity	Ensures broad visibility (EDR, Proxy, DNS)

What is EDR?

Endpoint Detection and Response (EDR) is a security solution designed to monitor, investigate, and respond to suspicious activity on **endpoint devices** such as desktops, laptops, or servers.

Think of EDR as a **camera and control system for every device** in your organization: it monitors what's happening, records it, and lets you react to threats in real time.

Key Capabilities:

- **Continuous monitoring** of processes, file changes, network connections, and user activity.
- **Data collection** for forensic analysis (logs, processes, registry edits, etc.).
- **Searchable database** across all endpoints.
- **Automated or manual responses**, such as file quarantines, process termination, or device isolation.

Popular EDR tools include **Carbon Black**, **SentinelOne**, **CrowdStrike Falcon**, and **FireEye HX**.

How SOC Analysts Use EDR

EDR is one of the **most powerful investigation tools** a SOC analyst can use. Here's how it helps in real scenarios:

1. Searching IOCs Across All Endpoints

If you detect a threat and extract an **Indicator of Compromise (IOC)** — like a file hash, process name, or IP address — you can search for this IOC across every device in the network.

Example:

You find the file hash `ac596d282e2f9b1501d66fce5a451f00` on a compromised machine.

You query this hash in EDR to see if the same file exists on **other devices**.

If it does, those machines are also likely compromised.

2. Investigating a Suspicious Device

Let's say an alert flags a particular workstation (e.g., WIN-CLIENT-01). With EDR, you can:

- View the **process list** (to spot abnormal programs running).
- Check **network connections** (see if it's talking to known bad IPs or C2 servers).
- Inspect **browser history** (look for phishing links or downloads).
- Review **recent file creation/modification** activities.

3. Live Investigation (Real-Time Access)

EDR often lets you **remotely connect** to the endpoint and explore:

- Filesystem contents
- Running services
- Registry keys
- Command history

This gives you **forensic-level visibility** without physically accessing the device.

4. Containment/Isolation

One of the most important features: **network isolation**.

Suppose a machine is compromised and communicating with a threat actor. You must **cut off its access to the rest of the network**, but still be able to investigate it.

EDR tools allow you to **contain** the machine:

- Blocks all external/internal communication.
- Still allows EDR communication (so you can analyze remotely).
- Prevents **lateral movement** by the attacker.
- Buys time for response and cleanup.

Quick Tips for Effective Use of EDR

Tip	Why It Matters
Always confirm file hashes, names, or processes across multiple endpoints	Prevents missing infections elsewhere
Use containment quickly in live attacks	Limits potential damage
Compare “normal” vs “abnormal” behavior	Helps in detecting stealthy attacks
Combine EDR data with log/SIEM data	Enables full end-to-end incident understanding

Workflow Example

An alert comes in: “Suspicious PowerShell command on WORKSTATION-02.”

As a SOC Analyst, you would:

1. Go to EDR and review the device's recent **process history**.
2. See the command: powershell.exe -enc aGVsbG8gd29ybGQ= (base64 encoded).
3. Decode and confirm it's malicious.
4. Use EDR to **contain the device**.
5. Search the same command or hash across all endpoints.
6. Document findings and escalate to Incident Response if needed.

Final Advice

- EDR is as important as Log Management and SIEM. Use all **three together** for full visibility.
- Practice navigating and investigating in your EDR platform regularly (like on LetsDefend).
- Don't rely only on alerts — use proactive searches and hypothesis-based threat hunting.

What is SOAR?

SOAR is a technology that connects different security tools and automates repetitive tasks, so that **SOC teams can detect, investigate, and respond to incidents more efficiently**.

In simple terms:

SIEM tells you something is wrong.

SOAR helps you fix it automatically — or at least a lot faster.

Why SOC Analysts Need SOAR

Main Benefits:

Benefit	Description
Time-saving automation	Repetitive tasks like IP lookups, hash queries, or sandbox scans can be automated.
Consistency in investigations	Using pre-defined playbooks ensures everyone follows the same process.
Centralized interface	Integrates multiple tools (SIEM, EDR, Threat Intel, Sandbox, etc.) in one dashboard.
Faster response	Enables immediate containment or response actions without waiting for human input.

How SOAR Works: Real Examples

1. Automating IOC Lookups

Let's say a SIEM alert shows suspicious activity from an IP.

Without SOAR:

- You manually copy the IP.
- Go to VirusTotal.
- Paste and check reputation.

With SOAR:

- The IP is **automatically queried** on VirusTotal or similar.
- The result is **attached to the alert ticket**.

 You save 2–3 minutes per alert — now multiply that across dozens of alerts per day.

2. Running a Playbook

Playbooks are step-by-step automated workflows that guide analysts through incident response.

For example, a playbook for a **phishing email** alert might include:

1. Extract sender IP, URLs, attachments.
2. Query reputation of all IOCs.
3. Submit attachment to sandbox.
4. Search for same email across mailboxes.
5. Contain infected endpoints (via EDR).
6. Notify SOC manager and create incident report.

All of this can be done **semi- or fully-automated** by SOAR.

Common SOAR Tasks

Task	Description
IP reputation check	Automatically queries IPs against threat intel feeds (VirusTotal, AlienVault, etc.)
File hash analysis	Looks up file hashes in databases or sandboxes
Email header analysis	Parses headers to identify spoofing or redirection
Log enrichment	Pulls additional logs related to an incident
Endpoint isolation	Sends command via EDR to isolate device
Ticket generation	Creates or updates tickets in case management tools

Common SOAR Tools in the Industry

Tool	Notes
Splunk Phantom	Strong integration with Splunk SIEM
IBM Resilient	Designed for large enterprise use
Cortex XSOAR (formerly Demisto)	Rich playbook and automation engine
Logsign SOAR	Popular in certain regions, user-friendly interface

Why SOAR Matters to You as a SOC Analyst

- **Efficiency:** Spend less time on repetitive work, more on real analysis.
- **Collaboration:** Everyone in your SOC team follows the same incident response process.
- **Quality:** Fewer steps missed; standardized responses across the team.
- **Scalability:** You can manage more incidents without burning out.

Practical Example with SOAR in Action

Scenario: SIEM triggers an alert for suspicious file download.

Without SOAR:

- You extract IP, domain, hash manually.
- Check them in different tools.
- Write a report from scratch.

With SOAR:

- IP/domain/hash are auto-enriched.
- Sandbox analysis is triggered.
- Report draft is auto-generated.
- You review results and make a final decision.

Result? You saved 15–20 minutes and had more consistent results.

Final Words

SOAR is your **productivity booster** in a SOC. It doesn't replace analysts — it **augments your capabilities**, so you can handle threats faster, with better accuracy, and less stress.

Key Takeaways:

- Learn to understand how playbooks work.
- Identify tasks you do repeatedly — see if SOAR can automate them.
- Always verify automated actions before executing critical changes (like isolation or blocking).

Threat Intelligence Feeds are **critical tools** in the day-to-day operations of a SOC analyst. They provide **real-time or near real-time data** about known and emerging cyber threats, helping security teams proactively defend their organization.

Let's go through this concept in detail to help you understand its role, usage, and limitations.

What is a Threat Intelligence Feed?

A **Threat Intelligence Feed** is a constantly updated stream of **data about malicious activity** on the internet. It usually includes:

- **IP addresses** of known malicious servers
- **Domain names** used in phishing or malware distribution
- **File hashes** of malicious software
- **URLs** used in attacks
- **Indicators of Compromise (IOCs)** tied to specific malware campaigns

These feeds are compiled and maintained by third-party cybersecurity vendors, government agencies, or communities.

How SOC Analysts Use Threat Intelligence Feeds

SOC analysts use threat intel feeds to:

1. **Enrich SIEM alerts:** Is this IP address in the alert linked to known malware or phishing campaigns?
2. **Validate IOCs:** Does the file hash appear in a malware database?

3. **Correlate past events:** Was this domain contacted by any host in the network last week?
4. **Hunt threats:** Search across logs or endpoints to see if anyone interacted with a known bad IOC.

Example Scenario:

An alert shows that a user downloaded a file. The file's hash is:
1a79a4d60de6718e8e5b326e338ae533

You check this hash on **VirusTotal**. It shows:

- Detection by 30+ antivirus engines
- Known distribution via phishing emails
- Linked to a Cobalt Strike beacon

✅ Now you know the file is **malicious**, and you can isolate the endpoint and start an incident report.

🌐 Trusted Threat Intelligence Feed Sources

Here are some **free and popular** threat intelligence feeds:

Source	Type	Description
VirusTotal	File, URL, IP	Aggregates AV and sandbox results
Talos Intelligence	IP, Domain, Reputation	Maintained by Cisco
AbuseIPDB	IP Reputation	User-reported malicious IPs
AlienVault OTX	Community Threat Sharing	Open threat exchange
Anomali ThreatStream	Paid/Free	Commercial threat intelligence

⚠️ Important Things to Keep in Mind

1. Absence of Data ≠ Clean

Just because a **hash or IP doesn't appear** in a threat feed doesn't mean it's safe.

❗ New or custom-built malware often **doesn't appear** in feeds immediately.

If an IOC is not found in the feed:

- Perform **static and dynamic analysis**.
- Check behavior using a **sandbox**.
- Inspect how the file behaves when executed.

2. IP Ownership Can Change

IP addresses are **not permanently tied to malicious use**. For instance:

- An AWS IP was once used as a malware server.
- That server was deleted, and now a personal blog is using the same IP.
- If you block the IP based solely on past behavior, you may disrupt legitimate services.

 Always **check the timestamp** and **context** of the malicious activity before acting.

Real-World Application in LetsDefend

On the LetsDefend platform, the **Threat Intelligence Feed page** gives you:

- Centralized access to hashes, IPs, and domains flagged as malicious
- Ability to search for an IOC found during alert investigation
- Insight into whether an IOC has been **previously seen and documented**

You might use it like this:

- You analyze an alert from SIEM
- Extract a file hash or suspicious IP
- Paste it into the Threat Intel Feed to check historical data
- Use the result to **confirm or deny** whether it's malicious

Summary: Key Takeaways

Concept	Summary
Purpose	Provides IOCs that help in investigation and threat detection
Usage	Enrich alerts, validate IOCs, hunt for threats
Limitation	Not finding data doesn't mean it's clean; analyze further
Tip	Consider context — old malicious IPs may now be clean

The **common mistakes made by SOC Analysts** and explore **why they happen, what risks they introduce, and how you can avoid them** with practical best practices.

1. Over-Reliance on VirusTotal Results

Mistake:

SOC analysts may trust a “green” or clean verdict from **VirusTotal (VT)** without deeper inspection.

Why It's Risky:

- VirusTotal is **not an endpoint or behavior-based detector**—it only scans files or URLs using signature-based AV engines.

- Modern malware uses **AV bypassing techniques** like obfuscation, packing, and encryption.
- A clean VT result might reflect **lack of AV detection**, not actual safety.

✅ **Best Practice:**

- Use VirusTotal **only as a reference**, not as your final judgment.
- If VT shows "no detection", **manually inspect the file or URL**:
 - Run in a controlled **sandbox**.
 - Perform **static/dynamic analysis**.
 - Check behavioral indicators (e.g., outbound network connections, file creation).
- Always **consider context**: Where was the file found? Was it expected?

🔗 **Additional Resource:**

[VirusTotal is not an Incident Responder \(blog\)](#)

🕒 **2. Hasty Analysis of Malware in a Sandbox**

❌ **Mistake:**

Relying on a **quick (3–5 minute)** sandbox execution to make decisions about malware.

🔧 **Why It's Risky:**

- **Advanced malware** can detect if it's running in a virtual or sandbox environment.
- Malware might include **delays** (e.g., sleep for 10 minutes) to evade fast analysis.
- Some require **user interaction** or **specific triggers** to activate.

✅ **Best Practice:**

- **Increase analysis time** in the sandbox (10–20 mins if possible).
- Use **multiple sandbox environments** for comparison.
- Perform **manual behavioral review**:
 - Network traffic analysis
 - Registry changes
 - File system operations

📊 **3. Inadequate Log Analysis**

❌ **Mistake:**

Only analyzing the compromised machine, ignoring whether **other endpoints** might be affected.

🔧 **Why It's Risky:**

- You may miss **lateral movement** or **coordinated attacks**.

- Overlooking related traffic (e.g., other systems talking to same IP/domain) delays detection.

✅ Best Practice:

- **Always pivot** from an IOC:
 - Use **Log Management tools** to search for the same IP, hash, or domain across all logs.
 - Search proxy, DNS, EDR, and firewall logs.
- Example:
 - Malware on HostA connects to malicious[.]io
 - Search logs: Did HostB, HostC also contact this domain?

📅 4. Overlooking VirusTotal Dates

❌ Mistake:

Trusting outdated or cached VirusTotal results **without revalidating** the content.

🔧 Why It's Risky:

- Cached results may reflect **previous state** of the content.
- Attackers can **upload benign files or URLs** to VT to gain a green label, then swap the file or redirect the URL to a **malicious payload**.

✅ Best Practice:

- Always click **"Reanalyze"** on VirusTotal to trigger a **fresh scan**.
- Check:
 - **Last analysis date**
 - **Reputation history**
 - **Change logs** for behavior or ownership

🧠 Summary Table

Mistake	Why It's Dangerous	How to Avoid It
Over-trusting VT	Misses stealthy/new malware	Use as a guide, not a verdict
Rushing sandbox analysis	Malware evades quick checks	Extend analysis time; use manual techniques
Not checking other devices	Misses spread of attack	Use logs to hunt across all systems
Ignoring VT cache age	May show outdated results	Always reanalyze, review timestamp

Final Thought

SOC analysts must balance speed with thoroughness. Relying too much on tools like VirusTotal or sandboxes without critical thinking leads to misjudgments. Being vigilant and following structured analysis steps will make you more effective and reliable in the SOC.

Would you like a checklist version of these mistakes for your own reference or training use?